perspective, CORS is awesome because it allows the server to open up its APIs to a new world of users.

This chapter gives an overview of what CORS is and how it's used. It begins by reviewing CORS's features and benefits. It then walks through the code to make a CORS request.

1.1 What is CORS?

CORS is simply a way of making HTTP requests from one place to another. This is a trivial thing in other programming languages. But it's difficult to do in client-side JavaScript, because for years the browser's same-origin policy has explicitly prevented these types of requests.

This may make CORS sound like a contradiction. How can CORS allow cross-origin requests if the same-origin policy explicitly forbids them? The key is that CORS puts servers firmly in charge of who can make requests, and what type of requests are allowed. A server has the choice to open up its API to all clients, open it up to a small number of clients, or prevent access to all clients.

So if browsers enforce a same-origin policy, how does CORS work? The secret lies in the request and response headers. The browser and the server use HTTP headers to communicate how cross-origin requests behave. Using the response headers, the server can indicate which clients can access the API, which HTTP methods or HTTP headers are allowed, and whether cookies are allowed in the request.

Figure 1.1 shows what an end-to-end CORS request to the Flickr API looks like.

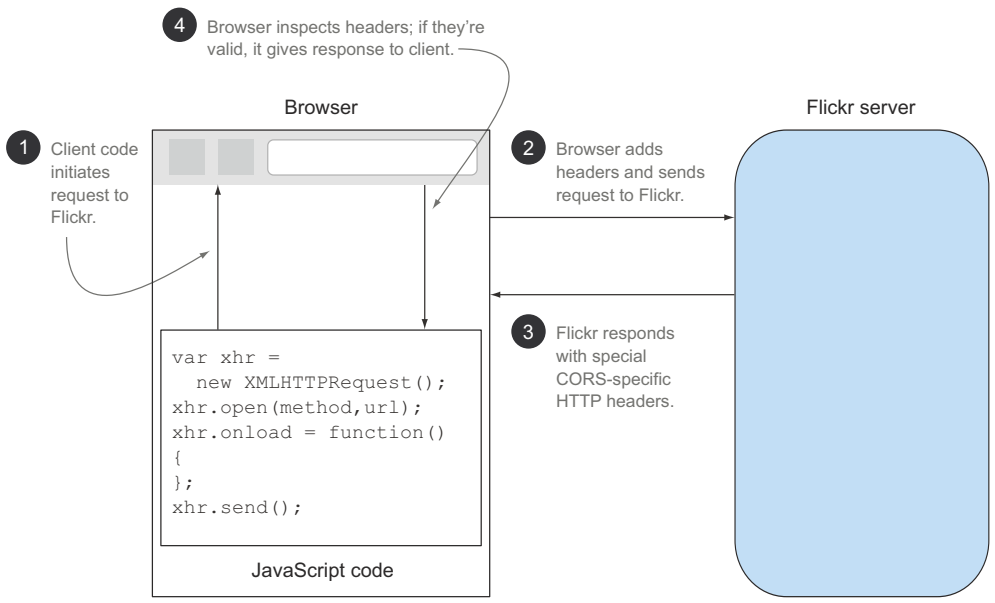


Figure 1.1 End-to-end CORS request flow